

Архитектура SMDG для службы информационной безопасности

Продукт: Secure Medical Data Gateway (SMDG)
Версия документа: 1.0 (выжимка)
Дата: 02 июня 2026
Источник: ARCHITECTURE.md, SECURITY.md, DEPLOYMENT.md
Сценарий: развёртывание у оператора ПДн (клиника); профиль **ru**
Документ предназначен для предварительной оценки ИБ. Не заменяет акт аттестации, модель угроз заказчика и заключение по 152-ФЗ.

1. Назначение и границы системы

SMDG — self-hosted шлюз для:

- загрузки и **шифрованного** хранения медицинских файлов (включая DICOM);
- выдачи **одноразовых** ссылок на скачивание с ограничением по времени и числу загрузок;
- просмотра DICOM** в браузере (рендеринг на сервере);
- аудита** действий пользователей и экспорта журналов.

Не входит в scope: МИС, PACS, ЕГИСЗ, биллинг, ЭМК — только обмен файлами и смежные функции безопасности.

Размещение: сервер или VPS **в контуре оператора** (РФ). Публичное демо (профиль **demo**): <https://fileguardian.info> — **не** использовать для реальных ПДн.

2. Высокоуровневая схема

```
[REDACTED]
| HTTPS (TLS 1.3)
v
[Nginx - reverse proxy, HSTS]
|
v
[FastAPI - SMDG Application]
|-- Middleware: tenant, auth, rate limit, audit
|-- API: upload, download, auth, admin, dicom, webhooks
|
+-- PostgreSQL (REDACTED, REDACTED, REDACTED)
+-- Redis (REDACTED, rate limit, REDACTED DICOM metadata)
+-- Storage: /encrypted (REDACTED, REDACTED ru)
+-- Crypto: age (REDACTED Docker Secrets)
+-- /decrypted - REDACTED, TTL-REDACTED
```

Принципы: Zero Trust на уровне приложения; расшифровка только на сервере; полный аудит операций.

3. Компоненты и назначение

Компонент	Назначение	Данные
Nginx	TLS-терминация, прокси	Не хранит ПДн
FastAPI	Бизнес-логика, авторизация	Обрабатывает в RAM/временных файлах
PostgreSQL	Учётки, метаданные файлов, токены	Служба метаданных
Redis	Rate limit, кэш	Метаданные DICOM (без полного снимка)
Local FS `/encrypted`	Хранение ciphertext	Зашифрованные медфайлы (.age)
age keys	Шифрование at rest	Криптоключи (secrets)
audit_logs/	Журнал событий	JSON-строки по операциям

4. Потоки данных (кратко)

4.1. Загрузка файла

1. Клиент → POST /api/upload (JWT cookie, rate limit).
2. Проверка MIME и размера.
3. Шифрование **age** → запись в /encrypted.
4. Запись метаданных в PostgreSQL, создание FileLink.
5. Событие в аудит; опционально webhook file.uploaded.

4.2. Скачивание по ссылке

1. Получатель → GET /api/download?token=... (без учётки).
2. Проверка токена, срока, лимита скачиваний.
3. Расшифровка → потоковая отдача → **удаление временного файла**.
4. Инкремент счётчика / инвалидация одноразовой ссылки.
5. Аудит file.downloaded.

4.3. DICOM Viewer

1. Авторизованный пользователь → POST /api/dicom/view-url → view-токен (TTL **15 мин**).
2. Рендер PNG / DICOMweb на сервере; расшифровка **в память** (без постоянной записи снимка).
3. Аудит: dicom.view_initiated, dicom.streamed и др.

5. Аутентификация и доступ

Механизм	Параметр
Сессия	JWT в HttpOnly + Secure cookie (`access_token`), TTL ~60 мин
2FA	TOTP (профиль `russia` — обязательна для всех)
Роли	`user`, `doctor`, `admin`, `super_admin`
Пароли	Argon2
API admin	Только `admin` / `super_admin` (экспорт аудита, пользователи)
Rate limiting	slowapi + Redis (login, upload, register)

Multi-tenancy: в профиле russia отключена (один tenant); в saas — изоляция по tenant_id и поддомену.

6. Шифрование и ключи

Объект	Метод
Файлы at rest	age (асимметричное шифрование)
Ключи	`/app/keys/`, Docker Secrets; ротация с перешифровкой
Транспорт	TLS 1.3 (Nginx)
Webhooks	HMAC-SHA256 (`X-Webhook-Signature`)

ГОСТ: в профиле russia флаг GOST_CRYPTO — **задел**; в промышленной поставке используется **age**. Переход на ГОСТ — отдельный проект.

7. Аудит и хранение журналов

- Формат: `audit\_logs/audit\_YYYY-MM-DD.log` (JSON построчно).

- Срок хранения (профиль `russia`): ****1095 дней**** (`AUDIT\_3\_YEARS`).
 - Экспорт: `GET /api/admin/audit/export` → CSV, Excel, PDF (только admin).
 - События: login, upload, download, delete, dicom.*, admin.*, ошибки.
- **Рекомендация ИБ:**** выгрузка журналов в SIEM заказчика — через периодический экспорт или чтение каталога audit_logs/ средствами ОС (log shipper).

8. Очистка и минимизация данных

Объект	Политика
Медфайлы	TTL по умолчанию **7 дней** (`TTL_DAYS`)
Временные расшифровки	Удаление после ответа / ≤ 1 ч
Одноразовые ссылки	TTL или после первого скачивания
DICOM view-токены	15 минут
Учётные записи	До удаления администратором

Планировщик: CleanupManager (APScheduler), метрика file_cleanup_deleted_total.

9. Профиль развёртывания `russia` (для клиник РФ)

Параметр	Значение
Хранилище	Только **локальное** (`S3_ENABLED=false`)
2FA	Обязательна для **всех** ролей
Аудит	3 года
S3 за рубежом	Отключено по матрице фич
Проверка в рантайме	`GET /health/features`, `GET /health/deployment`

Развёртывание: docker compose -f docker-compose.yml -f docker-compose.russia.yml up -d

10. Сеть и инфраструктура (рекомендации ИБ)

- Вход: ****443/tcp**** на Nginx; админ-доступ — по VPN или allowlist IP.
- Исходящий трафик: обновления ОС, Let's Encrypt (при использовании), ****без**** обязательной отправки медданных наружу.
- Резервное копирование: ****ответственность оператора**** — БД PostgreSQL + каталог `/encrypted` + `/app/keys` (по регламенту).
- Сегментация: размещение VM SMDG в DMZ или защищённом сегменте клиники; доступ к PostgreSQL/Redis только с хоста приложения.

11. Угрозы и компенсирующие меры

Угроза	Мера
Перехват в канале	TLS 1.3, HSTS
Компрометация диска	age at rest
Brute-force	Rate limit, 2FA
Вредоносные файлы	MIME whitelist, magic bytes
Утечка через логи	Аудит без содержимого файлов; контроль log level
Инсайдер	Роли, аудит, минимальные привилегии
Одноразовые ссылки	TTL, лимит скачиваний, инвалидация

12. Соответствие и ограничения

****Что документ описывает:****

- техническую архитектуру и встроенные механизмы защиты SMDG;
- настройки профиля `russia`, ориентированного на 152-ФЗ.

****Что документ не подтверждает:****

- соответствие конкретной клиники 152-ФЗ, приказу ФСТЭК № 21, категорированию КИИ;
- наличие сертификата ФСТЭК на СЗИ;
- регистрацию ПО как медицинского изделия.

Организационные меры и политики оператора — в COMPLIANCE_DRAFT_CONTRACTOR.md.

13. Контакты и материалы

Ресурс	URL
Исходный код (MIT)	https://github.com/valera7623/SMDG
Живое демо (`demo`)	https://fileguardian.info
Полная архитектура	docs/locales/ru/ARCHITECTURE.md
Безопасность	docs/locales/ru/SECURITY.md
Подрядчик по внедрению	Валерий Попов · valera7623@gmail.com

Конец документа.